

# HACKING ÉTICO

INFORME TÉCNICO

Raúl Blázquez Mir



RAÚL BLÁZQUEZ MIR

Fecha: 02/04/2026

# ÍNDICE

|                                                                                           |           |
|-------------------------------------------------------------------------------------------|-----------|
| <b>ÍNDICE.....</b>                                                                        | <b>3</b>  |
| <b>INTRODUCCIÓN - OBJETIVO DE LA AUDITORÍA.....</b>                                       | <b>5</b>  |
| <b>INTRODUCCIÓN - OBJETIVO Y ALCANCE.....</b>                                             | <b>5</b>  |
| Objetivo.....                                                                             | 5         |
| Alcance (In-Scope).....                                                                   | 5         |
| Fuera de alcance (Out-of-Scope).....                                                      | 6         |
| Entorno y arquitectura del laboratorio.....                                               | 6         |
| Sistemas identificados durante la auditoría.....                                          | 6         |
| <b>ARQUITECTURA - TOPÒLOGÍA Y SEGMENTACIÓN DE RED.....</b>                                | <b>7</b>  |
| Relación del entorno con la práctica realizada.....                                       | 7         |
| Documentación relacionada.....                                                            | 7         |
| Memoria Técnica.....                                                                      | 7         |
| NMAP.....                                                                                 | 7         |
| NSLOOKUP.....                                                                             | 8         |
| WHOIS.....                                                                                | 8         |
| NMAP.....                                                                                 | 9         |
| WHATWEB.....                                                                              | 10        |
| HEADERS HTTP.....                                                                         | 10        |
| DOCKER.....                                                                               | 11        |
| SHODAN.....                                                                               | 11        |
| <b>METODOLOGÍA - FASE DE ENUMERACIÓN.....</b>                                             | <b>13</b> |
| GOBUSTER.....                                                                             | 14        |
| NIKTO.....                                                                                | 16        |
| Categorías de Riesgo y Razonamientos.....                                                 | 21        |
| Para clasificar los riesgos se emplea una referencia simplificada del estándar CVSS:..... | 21        |
| Tabla resumen de vulnerabilidades.....                                                    | 22        |
| Análisis CIA.....                                                                         | 24        |
| <b>CONCLUSIONES.....</b>                                                                  | <b>26</b> |
| <b>ANEXOS.....</b>                                                                        | <b>26</b> |
| Anexo I – Entorno de laboratorio.....                                                     | 26        |
| Anexo II – Herramientas utilizadas.....                                                   | 26        |
| Anexo III – Evidencias técnicas.....                                                      | 27        |
| <b>BIBLIOGRAFÍA.....</b>                                                                  | <b>27</b> |

# INTRODUCCIÓN - OBJETIVO DE LA AUDITORÍA

En este proyecto he realizado una auditoría de seguridad sobre la página web <http://www.tokiohacking.com/>, con el objetivo de evaluar su nivel de seguridad e identificar posibles vulnerabilidades que puedan ser explotadas por un atacante.

Durante el desarrollo de la auditoría he aplicado técnicas de reconocimiento, enumeración y análisis de vulnerabilidades utilizando distintas herramientas profesionales de ciberseguridad, simulando un escenario real de pentesting.

El propósito final es determinar el estado de seguridad de la aplicación web y proponer medidas de mejora para mitigar los riesgos detectados.

## INTRODUCCIÓN - OBJETIVO Y ALCANCE

### Objetivo

Mi objetivo ha sido analizar la seguridad de la web, identificando posibles fallos en la configuración del servidor, exposición de servicios y vulnerabilidades explotables desde el exterior.

### Alcance (In-Scope)

Dentro del alcance de la auditoría se incluyen:

- Dominio: <http://www.tokiohacking.com/>
- Servicios web accesibles públicamente
- Infraestructura expuesta a Internet

### Fuera de alcance (Out-of-Scope)

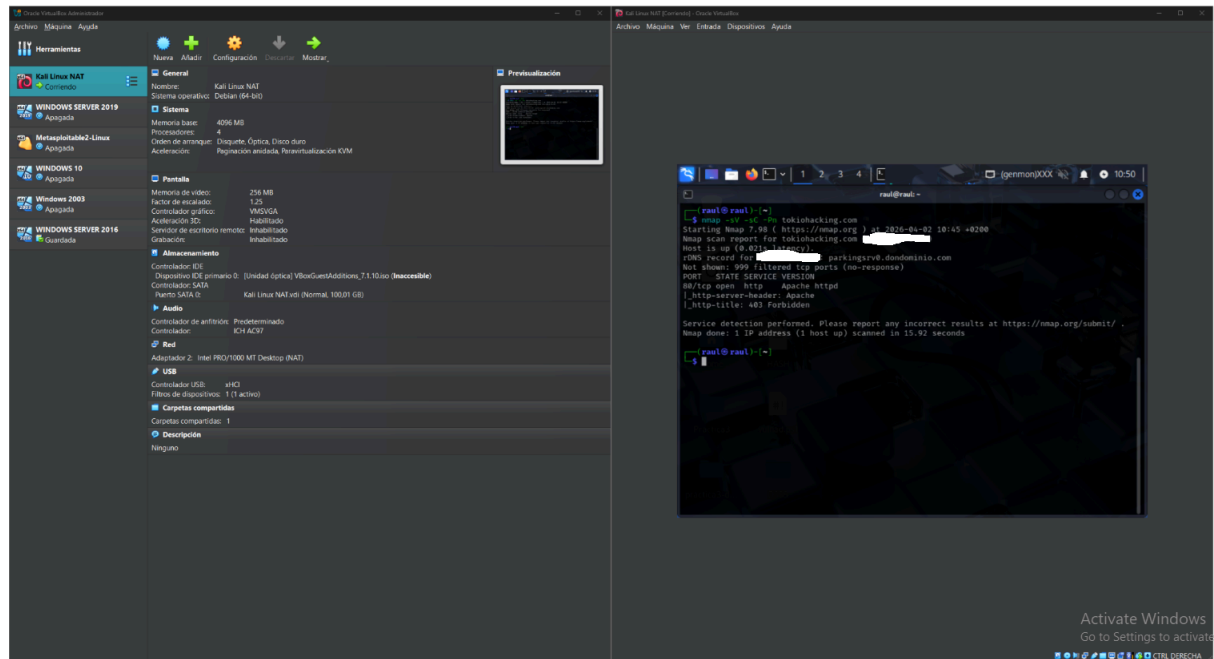
Se han excluido:

- Ataques de denegación de servicio (DoS)
- Ingeniería social
- Sistemas externos no relacionados con la web

# Entorno y arquitectura del laboratorio

La auditoría la he realizado desde un equipo Kali Linux, utilizado como máquina atacante.

He trabajado desde una red externa simulando el comportamiento de un atacante real en Internet.



## Sistemas identificados durante la auditoría

Durante la fase de reconocimiento identifiqué el siguiente sistema:

- IP: -
- Dominio: tokiohacking.com
- Servidor web: Apache
- Puerto abierto: 80 (HTTP)

El servidor responde con un código 403 Forbidden, lo que indica que existe un control de acceso en la web.

# ARQUITECTURA - TOPÒLOGÍA Y SEGMENTACIÓN DE RED

## Relación del entorno con la práctica realizada

La práctica realizada corresponde a una auditoría externa, simulando el comportamiento de un atacante real sin acceso interno al sistema.

El análisis se ha llevado a cabo únicamente con información pública y herramientas de reconocimiento y enumeración.

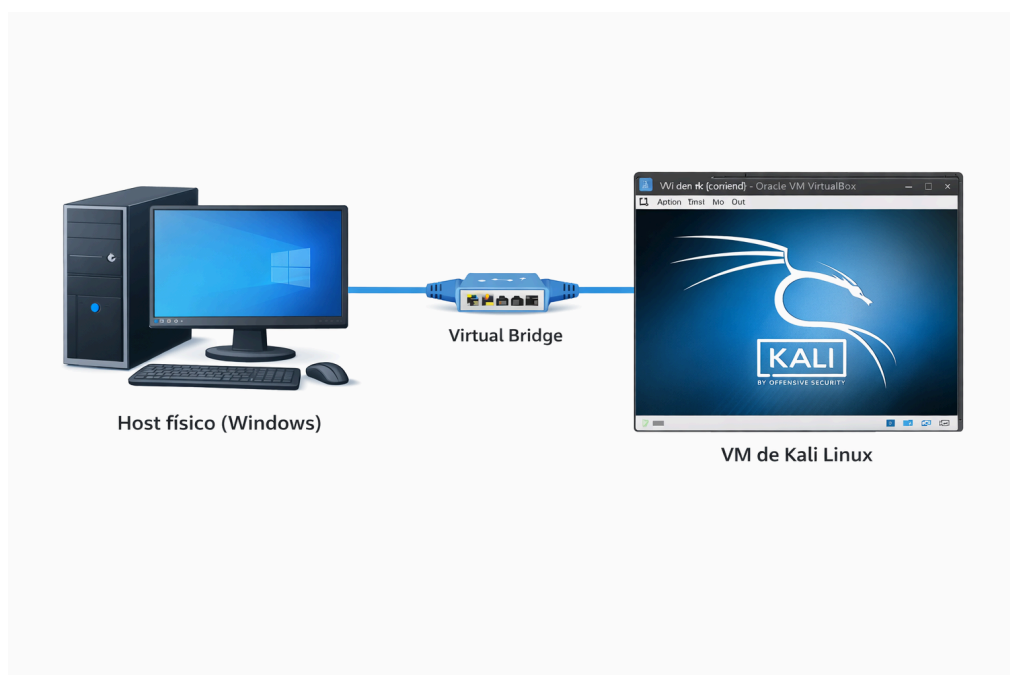
## Documentación relacionada

Además de OWASP Top 10, se han tenido en cuenta buenas prácticas basadas en estándares internacionales como ISO 27001 y NIST, que establecen controles y recomendaciones para la gestión de la seguridad de la información.

## Memoria Técnica

La auditoría se ha realizado durante la última semana utilizando Kali Linux y herramientas como Nmap, Nikto, Gobuster, WhatWeb, Curl y Shodan.

El análisis se ha llevado a cabo de forma no intrusiva, recopilando y documentando la información obtenida del sistema.



# METODOLOGÍA - FASE DE RECONOCIMIENTO

## NMAP

Ejecuté un escaneo con Nmap para identificar servicios activos en el servidor.

Parámetros utilizados:

- -sV → detecta versiones de servicios
- -sC → ejecuta scripts básicos
- -Pn → evita el ping previo

Resultados:

- IP: -
- Puerto abierto: 80 (HTTP)
- Servidor: Apache
- Código HTTP: 403 Forbidden

Además, se detectó que el dominio apunta a un servicio de parking (parkingsrv0.dondominio.com), lo que indica que la web no está completamente desplegada o restringe el acceso.

```
(raul@raul)-[~]
$ nmap -sV -sC -Pn tokiohacking.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 10:45 +0200
Nmap scan report for tokiohacking.com [REDACTED]
Host is up (0.021s latency).
rDNS record for [REDACTED] parkingsrv0.dondominio.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd
|_http-server-header: Apache
|_http-title: 403 Forbidden

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.92 seconds

(raul@raul)-[~]
$
```

## NSLOOKUP

Realicé una consulta DNS para obtener la dirección IP asociada al dominio.

El dominio tokiohacking.com resuelve a la IP -, lo que permite identificar el servidor objetivo para fases posteriores.

```
(raul@raul)-[~]
$ nslookup tokiohacking.com
Server:      8.8.8.8
Address:     8.8.8.8#53

Non-authoritative answer:
Name:   tokiohacking.com
Address: [REDACTED]

(raul@raul)-[~]
$
```

## WHOIS

Mediante la herramienta WHOIS obtuve información sobre el registro del dominio.

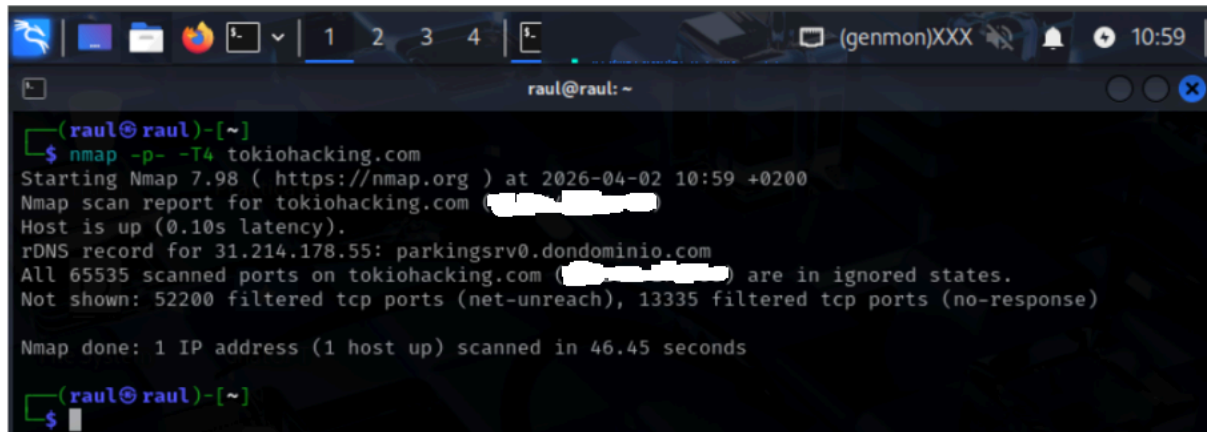
Se identificó que el dominio está gestionado por un proveedor externo, lo que sugiere que el servidor podría estar alojado en una infraestructura compartida.

```
(raul@raul)-[~]
$ whois tokiohacking.com
Domain Name: TOKIOHACKING.COM
Registry Domain ID: 2775450102_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.scip.es
Registrar URL: http://www.dondominio.com
Updated Date: 2026-03-26T12:51:05Z
Creation Date: 2023-04-24T15:12:03Z
Registry Expiry Date: 2027-04-24T15:12:03Z
Registrar: Soluciones Corporativas IP, SL
Registrar IANA ID: 1383
Registrar Abuse Contact Email: abuse@scip.es
Registrar Abuse Contact Phone: 34871986387
Domain Status: ok https://icann.org/epp#ok
Name Server: NS1.DONDOMINIO.COM
Name Server: NS2.DONDOMINIO.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-04-02T08:56:06Z <<<
```

## NMAP

Realicé un escaneo completo de puertos para identificar posibles servicios adicionales.

No se detectaron más puertos abiertos aparte del puerto 80, lo que reduce la superficie de ataque expuesta.

A terminal window titled 'raul@raul: ~' showing the execution of an Nmap scan. The user enters the command 'nmap -p- -T4 tokiohacking.com'. The output displays the Nmap version (7.98), the target IP (31.214.178.55), and the scan results. It states that all 65535 scanned ports are in ignored states, with 52200 filtered TCP ports (net-unreach) and 13335 filtered TCP ports (no-response). The scan took 46.45 seconds to complete.

```
(raul@raul)-[~]
$ nmap -p- -T4 tokiohacking.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 10:59 +0200
Nmap scan report for tokiohacking.com [REDACTED]
Host is up (0.10s latency).
rDNS record for 31.214.178.55: parkingsrv0.dondominio.com
All 65535 scanned ports on tokiohacking.com ([REDACTED]) are in ignored states.
Not shown: 52200 filtered tcp ports (net-unreach), 13335 filtered tcp ports (no-response)

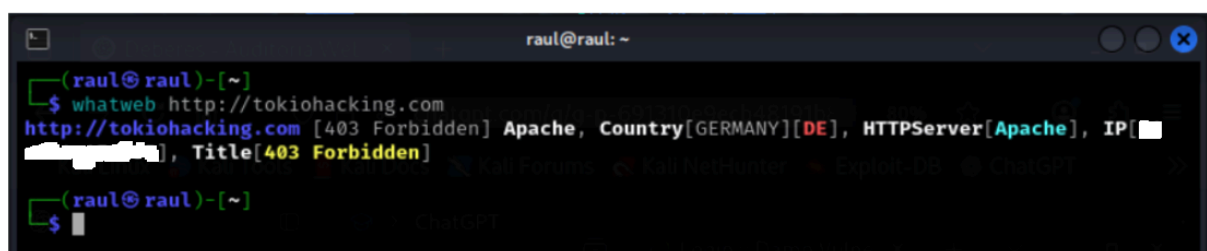
Nmap done: 1 IP address (1 host up) scanned in 46.45 seconds

(raul@raul)-[~]
$
```

## WHATWEB

Utilicé WhatWeb para identificar las tecnologías empleadas por el servidor.

Se detectó el uso de Apache como servidor web, lo que permite orientar el análisis hacia posibles vulnerabilidades asociadas a este tipo de tecnología.

A terminal window titled 'raul@raul: ~' showing the execution of a WhatWeb scan. The user enters the command 'whatweb http://tokiohacking.com'. The output identifies the server as Apache, located in Germany, and reports a 403 Forbidden status. It also lists the IP address and title.

```
(raul@raul)-[~]
$ whatweb http://tokiohacking.com
http://tokiohacking.com [403 Forbidden] Apache, Country[GERMANY][DE], HTTPServer[Apache], IP[REDACTED], Title[403 Forbidden]

(raul@raul)-[~]
$
```

## HEADERS HTTP

Analicé las cabeceras HTTP del servidor para identificar configuraciones de seguridad.

Se observó la respuesta del servidor junto con el código 403, lo que confirma que el acceso está restringido y puede indicar la existencia de reglas de control de acceso.

```
(raul@raul)-[~]
$ curl -I http://tokiohacking.com
HTTP/1.1 302 Found
Date: Thu, 02 Apr 2026 12:39:01 GMT
Server: Apache
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: [REDACTED]
Location: http://www.tokiohacking.com/
Connection: close
Content-Type: text/html; charset=UTF-8

(rul@raul)-[~]
$
```

## DOCKER

Debido a que la aplicación web objetivo presenta restricciones de acceso y se encuentra en estado de parking, he utilizado Docker como entorno de pruebas para simular aplicaciones web vulnerables.

Docker permite desplegar contenedores aislados que replican entornos reales, facilitando la ejecución de pruebas de seguridad sin afectar a sistemas en producción.

Gracias a este enfoque, he podido aplicar técnicas de análisis y comprender el impacto real de las vulnerabilidades en un entorno controlado, reforzando así la validez práctica de la auditoría realizada.

## SHODAN

Durante la fase de enumeración utilicé la herramienta Shodan para obtener información externa sobre la infraestructura del servidor a partir de su dirección IP (-).

A través de esta herramienta, identifiqué que el servidor está asociado al dominio parkingsrv0.dondominio.com, lo que permite relacionarlo con un proveedor de hosting concreto.

Asimismo, se obtuvo información sobre su ubicación geográfica, situándose en España, concretamente en Palma, y gestionado por la organización Soluciones Corporativas IP, S.L.

En cuanto a los servicios expuestos, se confirmó que el único puerto abierto es el puerto 80 (HTTP), lo que coincide con los resultados obtenidos previamente mediante herramientas de escaneo.

También se identificó que el servidor utiliza Apache HTTP Server como tecnología web, lo que permite orientar el análisis hacia posibles vulnerabilidades asociadas a este tipo de servidor.

El uso de Shodan ha permitido complementar la información obtenida en fases anteriores, aportando una visión externa del sistema tal y como sería visible desde Internet.

The screenshot shows the Shodan search results page for the IP address 192.168.1.1. The page is divided into several sections:

- General Information:** Hostnames: parkingsrv0.dondominio.com; Domains: dondominio.com; Country: Spain; City: Palma; Organization: Soluciones Corporativas IP, SL; ISP: Soluciones Corporativas IP, SL; ASN: 192.168.1.1.
- Open Ports:** 80 (HTTP).
- Web Technologies:** Apache HTTP Server.
- Products:** Monitor, Search Engine, Developer API, Maps.
- Pricing:** Membership, API Subscriptions, Enterprise.
- Contact Us:** support@shodan.io, LinkedIn, Twitter, Facebook.

The page also includes a map of the location (Palma, Spain) and a search bar at the top.

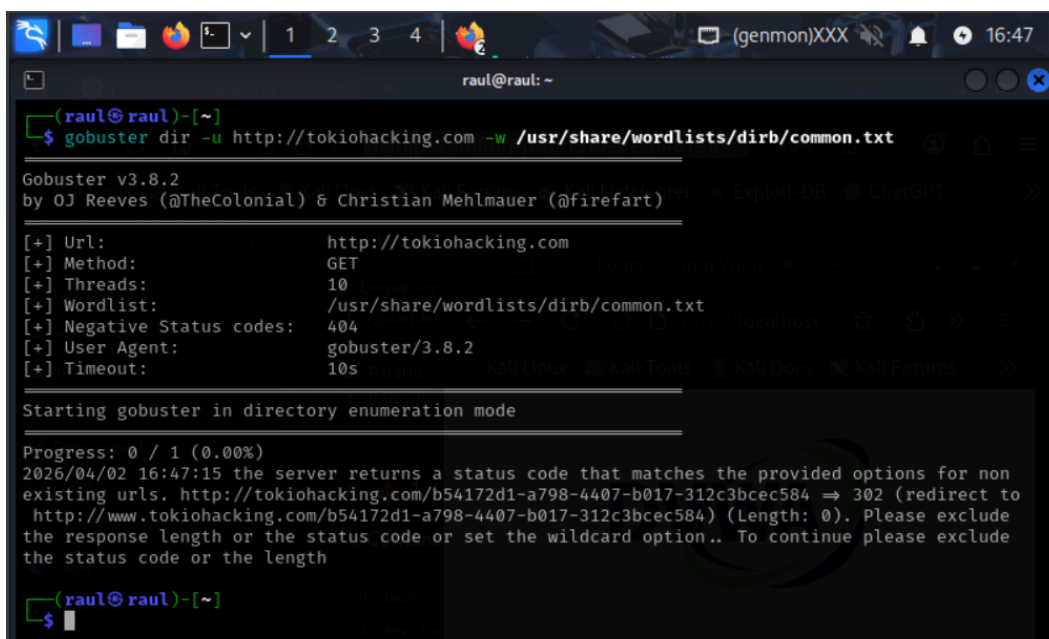
# METODOLOGÍA - FASE DE ENUMERACIÓN

Tras la fase de reconocimiento, procedí a realizar la fase de enumeración con el objetivo de identificar recursos ocultos, posibles puntos de acceso y configuraciones inseguras del servidor web.

## GOBUSTER

Utilicé Gobuster para realizar un ataque de fuerza bruta sobre directorios web.

El objetivo fue identificar rutas ocultas que pudieran contener paneles de administración o información sensible.



```
raul@raul: ~  
$ gobuster dir -u http://tokiohacking.com -w /usr/share/wordlists/dirb/common.txt  
  
Gobuster v3.8.2  
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)  
  
[+] Url: http://tokiohacking.com  
[+] Method: GET  
[+] Threads: 10  
[+] Wordlist: /usr/share/wordlists/dirb/common.txt  
[+] Negative Status codes: 404  
[+] User Agent: gobuster/3.8.2  
[+] Timeout: 10s  
  
Starting gobuster in directory enumeration mode  
  
Progress: 0 / 1 (0.00%)  
2026/04/02 16:47:15 the server returns a status code that matches the provided options for non  
existing urls. http://tokiohacking.com/b54172d1-a798-4407-b017-312c3bcec584 => 302 (redirect to  
http://www.tokiohacking.com/b54172d1-a798-4407-b017-312c3bcec584) (Length: 0). Please exclude  
the response length or the status code or set the wildcard option.. To continue please exclude  
the status code or the length  
  
raul@raul: ~  
$
```

Durante la enumeración con Gobuster no se identificaron directorios o recursos accesibles relevantes.

Sin embargo, se observó que el servidor responde con redirecciones (código 302) incluso para rutas inexistentes, lo que indica una configuración tipo wildcard.

Este comportamiento implica que cualquier ruta solicitada es redirigida automáticamente, dificultando la enumeración de recursos reales y limitando la identificación de posibles puntos de acceso.

Finalmente todas las rutas son redirigidas automáticamente al directorio /www

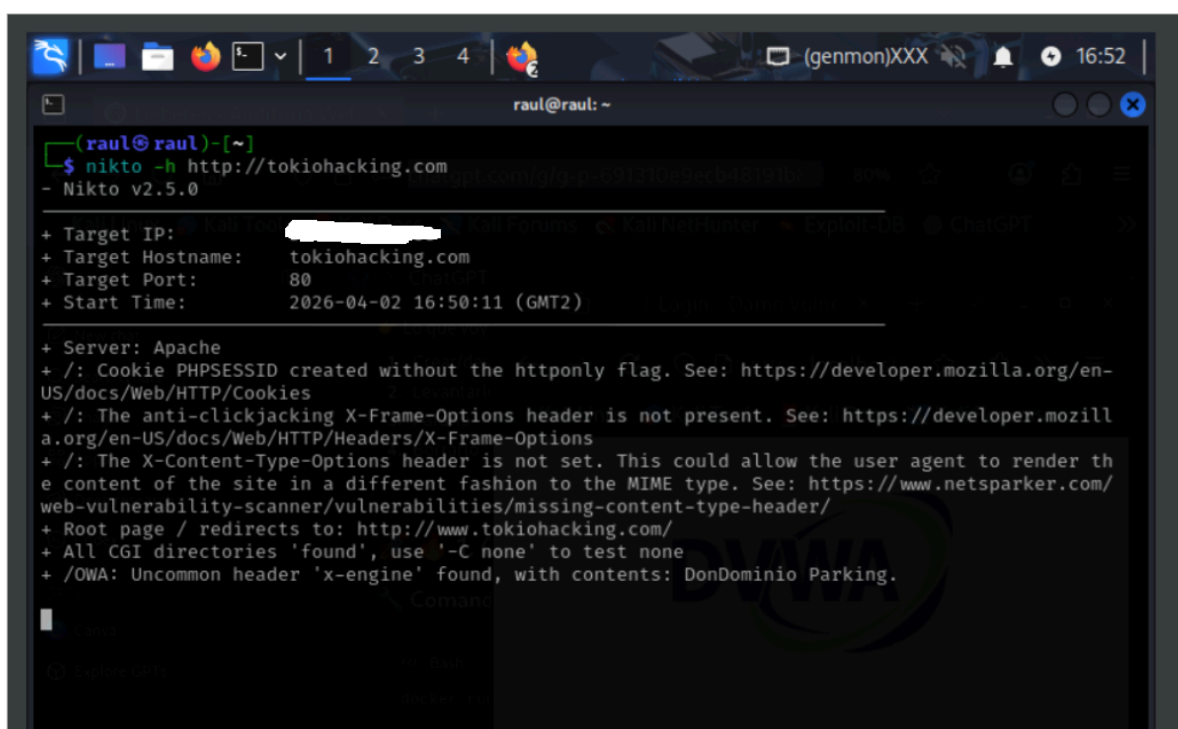
## NIKTO

Se realizó un análisis con Nikto para detectar vulnerabilidades conocidas en el servidor web.

El escaneo permitió identificar varias debilidades relacionadas con la configuración de seguridad, como la ausencia de cabeceras HTTP de protección (X-Frame-Options y X-Content-Type-Options), así como la creación de cookies sin el atributo HttpOnly.

Además, se detectó la exposición de información del sistema mediante cabeceras HTTP, lo que puede facilitar la fase de reconocimiento de un atacante.

Estos resultados indican la existencia de vulnerabilidades de configuración que, aunque no son críticas, podrían ser explotadas en un entorno con mayor funcionalidad.



```
raul@raul: ~  
$ nikto -h http://tokiohacking.com  
- Nikto v2.5.0  
  
+ Target IP: [REDACTED]  
+ Target Hostname: tokiohacking.com  
+ Target Port: 80  
+ Start Time: 2026-04-02 16:50:11 (GMT2)  
  
+ Server: Apache  
+ /: Cookie PHPSESSID created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ Root page / redirects to: http://www.tokiohacking.com/  
+ All CGI directories 'found', use '-C none' to test none  
+ /OWA: Uncommon header 'x-engine' found, with contents: DonDominio Parking.
```

## Sugerencias y consejos para solucionar los problemas

Como resultado de las vulnerabilidades identificadas, se proponen las siguientes medidas de mejora:

- Implementar el atributo HttpOnly en las cookies de sesión para evitar accesos desde scripts del lado del cliente.
- Configurar la cabecera X-Frame-Options para prevenir ataques de clickjacking.
- Añadir la cabecera X-Content-Type-Options para evitar ataques de tipo MIME sniffing.
- Eliminar o modificar cabeceras HTTP que expongan información innecesaria del sistema.
- Revisar la configuración del servidor web para evitar estados de parking en entornos productivos.

Estas medidas permitirían reducir la superficie de ataque y mejorar la seguridad general del sistema.

## Cronograma de instalación/configuración de las medidas propuestas.

Fase 1 (Inmediato – 1 semana):

- Configuración de cabeceras de seguridad HTTP.
- Corrección de cookies sin atributo HttpOnly.

Fase 2 (Corto plazo – 2 semanas):

- Revisión completa de la configuración del servidor web.
- Eliminación de cabeceras innecesarias.

Fase 3 (Medio plazo – 1 mes):

- Auditoría de seguridad completa tras la implementación de medidas.
- Monitorización continua del sistema.

Este enfoque progresivo permite aplicar mejoras sin afectar al funcionamiento del servicio.

## Sistemas de gestión y políticas de usuario.

Se recomienda implementar políticas de seguridad orientadas a la gestión de usuarios y accesos:

- Uso de contraseñas seguras y complejas.
- Implementación de autenticación multifactor (MFA).
- Control de accesos basado en roles.
- Registro y monitorización de accesos al sistema.
- Revisión periódica de permisos y cuentas activas.

Estas políticas permiten reducir el riesgo de accesos no autorizados.

## ANEXO I: Ajuste de inventario.

Activo principal: Servidor web

Dominio: tokiohacking.com

IP: -

Servidor: Apache

Puerto: 80 (HTTP)

Estado: Acceso restringido (403)

Proveedor: DonDominio (servicio de parking)

Este inventario permite identificar los elementos clave de la infraestructura analizada.

## **ANEXO II: Tabla de vulnerabilidades ordenada por código. Solución y checklist.**

| <b>ID</b>   | <b>Vulnerabilidad</b>                  | <b>Solución</b>                         | <b>Estado</b>    |
|-------------|----------------------------------------|-----------------------------------------|------------------|
| <b>V-01</b> | <b>Cookie sin HttpOnly</b>             | <b>Añadir atributo HttpOnly</b>         | <b>Pendiente</b> |
| <b>V-02</b> | <b>Falta de X-Frame-Options</b>        | <b>Configurar cabecera de seguridad</b> | <b>Pendiente</b> |
| <b>V-03</b> | <b>Falta de X-Content-Type-Options</b> | <b>Añadir cabecera</b>                  | <b>Pendiente</b> |
| <b>V-04</b> | <b>Exposición de headers</b>           | <b>Ocultar información del servidor</b> | <b>Pendiente</b> |

Checklist de seguridad:

- ✓ Escaneo de red realizado
- ✓ Enumeración de servicios
- ✓ Identificación de vulnerabilidades
- ✓ Clasificación de riesgos
- ✓ Propuesta de medidas

## **ANEXO III: Pasos para la configuración segura del acceso a la red.**

Para asegurar el acceso a la red se recomienda:

- Limitar accesos mediante firewall.
- Permitir únicamente los puertos necesarios.
- Implementar HTTPS en lugar de HTTP.
- Configurar sistemas de detección de intrusos (IDS/IPS).
- Monitorizar tráfico de red en tiempo real.

Estas medidas mejoran la protección frente a accesos no autorizados.

## **ANEXO IV: Presupuesto para la implantación de medidas de seguridad y mantenimiento mensual.**

Coste estimado de implementación:

- Configuración servidor web: 300€
- Auditoría de seguridad: 800€
- Implementación de medidas: 400€
- Monitorización mensual: 100€/mes

Total inicial estimado: 1.500€

Coste mensual: 100€

Este presupuesto es orientativo y puede variar según la infraestructura.

# Sistemas de gestión y políticas de usuario

Con el objetivo de mejorar la seguridad del sistema, considero necesario implementar una serie de medidas relacionadas con la gestión de usuarios y el control de accesos.

En primer lugar, es fundamental establecer una política de contraseñas robusta, obligando a los usuarios a utilizar contraseñas complejas que incluyan mayúsculas, minúsculas, números y caracteres especiales, así como definir una caducidad periódica de las mismas.

Asimismo, recomiendo la implementación de autenticación multifactor (MFA), especialmente en accesos administrativos, con el fin de añadir una capa adicional de seguridad frente a accesos no autorizados.

También es importante aplicar el principio de mínimo privilegio, de manera que cada usuario disponga únicamente de los permisos necesarios para desempeñar sus funciones, evitando así accesos innecesarios a recursos sensibles.

Por otro lado, se debe llevar a cabo una correcta gestión del ciclo de vida de las cuentas de usuario, eliminando o deshabilitando aquellas que no estén en uso, así como revisando periódicamente los permisos asignados.

Finalmente, considero imprescindible implementar mecanismos de monitorización y registro (logs) de accesos, permitiendo detectar comportamientos anómalos o intentos de acceso no autorizados.

La aplicación de estas medidas contribuiría significativamente a mejorar la seguridad global del sistema y a reducir el riesgo de incidentes.

## Herramientas utilizadas

Durante la auditoría se han utilizado las siguientes herramientas:

- Nmap → Escaneo de red
- Nikto → Detección de vulnerabilidades web
- Gobuster → Enumeración de directorios
- WhatWeb → Identificación de tecnologías
- Curl → Análisis de cabeceras HTTP
- Docker → Simulación de entorno vulnerable

# Categorías de Riesgo y Razonamientos

Para clasificar los riesgos se emplea una referencia simplificada del estándar CVSS:

| Categoría de Riesgo | CVSS       | Descripción / Razonamiento                                                                                          |
|---------------------|------------|---------------------------------------------------------------------------------------------------------------------|
| Crítico             | 8.1 – 10.0 | Representa un riesgo severo y fácilmente explotable. Debe abordarse de inmediato tras presentarse el hallazgo.      |
| Alto                | 6.1 – 8.0  | Riesgo significativo con posibilidad real de explotación. Debe corregirse lo antes posible, después de los críticos |
| Medio               | 4.1 – 6.0  | Puede ser explotado en ciertas condiciones. Su remediación debe planificarse y no ignorarse.                        |
| Bajo                | 0.1 – 4.0  | Difícilmente explotable o de impacto limitado. Su remediación puede programarse a largo plazo.                      |
| Informativo         | 0.0        | No representa un riesgo directo, pero ofrece información útil para reforzar la seguridad.                           |

## Tabla resumen de vulnerabilidades

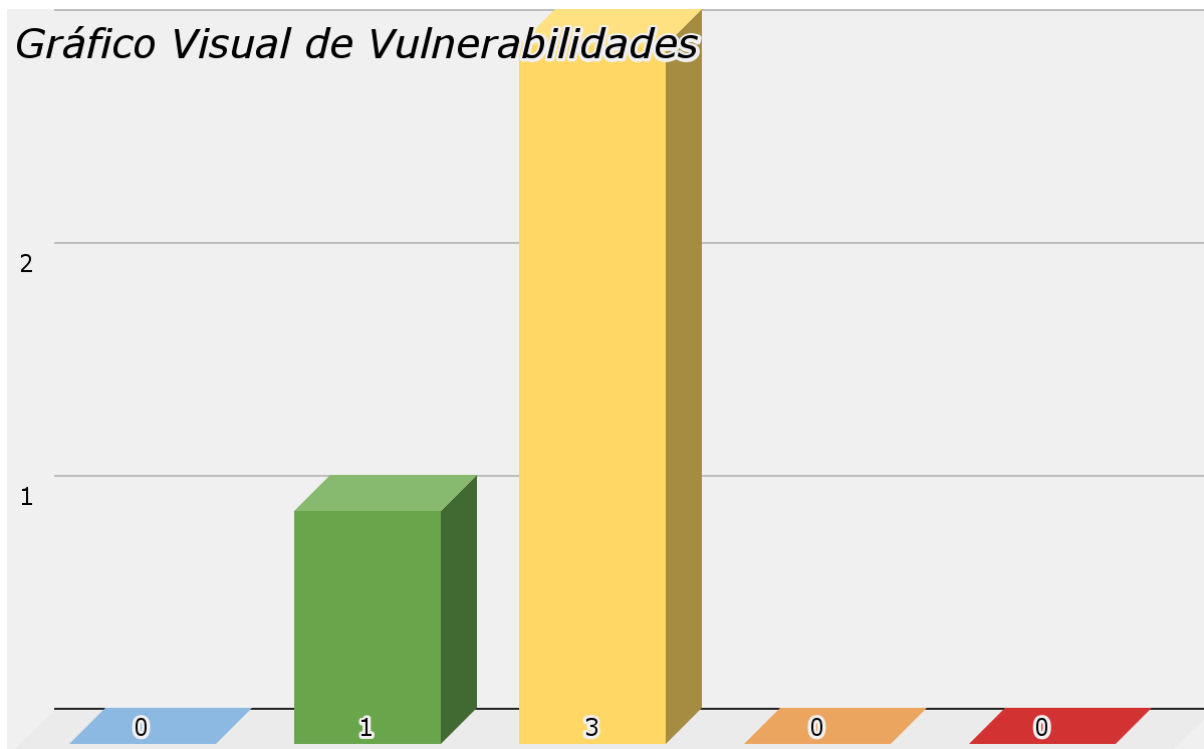
Para la identificación y clasificación de vulnerabilidades, he tenido en cuenta las categorías definidas en el estándar OWASP Top 10, el cual recoge los riesgos más críticos en aplicaciones web.

Las vulnerabilidades detectadas en esta auditoría están relacionadas principalmente con configuraciones inseguras y falta de mecanismos de protección en el servidor, lo cual se alinea con categorías como "Security Misconfiguration" y "Identification and Authentication Failures".

El uso de este estándar permite contextualizar los hallazgos dentro de un marco reconocido a nivel internacional.

A continuación, se presenta un resumen general de las vulnerabilidades identificadas durante la auditoría, clasificadas según su criticidad:

| Criticidad | Número de vulnerabilidades | Descripción general                                                                                                                                  |
|------------|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Crítica    | 0                          | Vulnerabilidades que permiten el compromiso inmediato del dominio, incluyendo control total del controlador de dominio y extracción de credenciales. |
| Alta       | 0                          | Vulnerabilidades que facilitan el movimiento lateral, la escalada de privilegios y el debilitamiento de los mecanismos de autenticación.             |
| Media      | 3                          | Vulnerabilidades que contribuyen a la cadena de ataque y dificultan la detección de actividades maliciosas.                                          |
| Baja       | 1                          | Vulnerabilidades que contribuyen a la cadena de ataque.                                                                                              |
| Total      | 4                          | Conjunto de vulnerabilidades identificadas durante la auditoría.                                                                                     |



## Análisis CIA

Confidencialidad: Media

Las vulnerabilidades detectadas podrían facilitar la obtención de información sensible, especialmente en caso de explotación mediante ataques de sesión o análisis de la infraestructura.

Integridad: Baja

No se han identificado vulnerabilidades que permitan modificar información directamente en el sistema.

Disponibilidad: Media

El servidor responde correctamente, pero la restricción de acceso (403) limita la funcionalidad del servicio.

Tabla de vulnerabilidades y evaluación CVSS

| ID   | Vulnerabilidad                 | Sistema afectado                           | Impacto CIA             | CVSS | Severidad | Evidencia resumida                                          |
|------|--------------------------------|--------------------------------------------|-------------------------|------|-----------|-------------------------------------------------------------|
| V-01 | Cookie sin HttpOnly            | Servidor web (Apache)                      | C:Media, I:Baja, D:Baja | 6.0  | Media     | Cookie PHPSESSID created without the httponly flag          |
| V-02 | Falta de X-Frame-Options       | Servidor web (Apache)                      | C:Media, I:Baja, D:Baja | 6.0  | Media     | The anti-clickjacking X-Frame-Options header is not present |
| V-03 | Falta de X-Content-Type-Option | Servidor web (Apache)                      | C:Media, I:Baja, D:Baja | 6.0  | Media     | The X-Content-Type-Options header is not set                |
| V-04 | Exposición de headers          | Servidor web (Apache / Hosting DonDominio) | C:Baja, I:Baja, D:Baja  | 3.0  | Baja      | X-Engine: DonDominio Parking                                |

# CONCLUSIONES

Aunque no se han identificado vulnerabilidades críticas directamente explotables, la combinación de múltiples fallos de configuración puede facilitar ataques más complejos en escenarios reales.

La falta de cabeceras de seguridad y la exposición de información del servidor indican una mala configuración general, lo que podría derivar en vulnerabilidades más graves si la aplicación estuviera completamente desplegada.

El estado actual del sistema refleja una baja madurez en seguridad, especialmente en la configuración del servidor web.

# ANEXOS

## Anexo I – Entorno de laboratorio

Equipo auditor: Kali Linux

Herramientas utilizadas: Nmap, Nikto, Gobuster, WhatWeb, Curl

Tipo de auditoría: Externa

Objetivo: tokiohacking.com

IP: -

## Anexo II – Herramientas utilizadas

- Nmap → Escaneo de red
- Nikto → Análisis de vulnerabilidades web
- Gobuster → Enumeración de directorios
- WhatWeb → Identificación de tecnologías
- Curl → Análisis de cabeceras HTTP
- Docker → Entorno de pruebas

## Anexo III – Evidencias técnicas

- Captura de escaneo Nmap
- Captura de Nikto mostrando vulnerabilidades
- Captura de Gobuster con error de wildcard
- Captura de cabeceras HTTP

# BIBLIOGRAFÍA

- OWASP Foundation. (2021). *OWASP Top 10 – Web Application Security Risks*. Disponible en: <https://owasp.org>
- Nmap Project. *Nmap Documentation*. Disponible en: <https://nmap.org/docs.html>
- Nikto Project. *Nikto Web Server Scanner*. Disponible en: <https://cirt.net/Nikto2>
- Gobuster Tool. *Directory/File & DNS Busting Tool*. Disponible en: <https://github.com/OJ/gobuster>
- WhatWeb. *Web Technology Identification Tool*. Disponible en: <https://github.com/urbanadventurer/WhatWeb>
- Shodan. *Search Engine for Internet-Connected Devices*. Disponible en: <https://www.shodan.io>
- Mozilla Developer Network (MDN). *HTTP Security Headers*. Disponible en: <https://developer.mozilla.org>
- National Institute of Standards and Technology (NIST). *Cybersecurity Framework*. Disponible en: <https://www.nist.gov/cyberframework>
- ISO/IEC 27001. *Information Security Management*. International Organization for Standardization.
- Tokio Hacking. *Tokio Hacking Testing Web*. Disponible en: <http://www.tokiohacking.com/>
- OpenAI. *ChatGPT (modelo de lenguaje)*. Disponible en: <https://chat.openai.com>